Information Security Policy

Owner: Admin (security) · **Applies to:** everyone with a Kestrel account · **Version:** 5.0, 1 May 2026

KestrelTrack stores live locations of drivers and delivery details for hundreds of businesses. A single leaked laptop or password can expose that data. This policy is short on purpose: every rule here is mandatory.

1. Classifying information

Level	What it covers	Examples	Can be shared with
Public	Already published	Website, press releases	Anyone
Internal	Day-to-day company information	Org chart, this policy, team plans	Anyone at Kestrel
Confidential	Customer and business information	Customer names, roadmaps, source code	People at Kestrel who need it
Restricted	The most sensitive data	Salaries, performance ratings, contracts, production data	Named people only

If you're not sure, treat it as Confidential.

2. Passwords and sign-in

- Passwords must be at least **14 characters**. A passphrase of four or more random words is recommended.
- Use the company password manager (1Password) for all work passwords.
- **Multi-factor authentication (MFA) is mandatory** on every work account, using the authenticator app. **SMS codes are not allowed** as a second factor.
- You don't have to change your password on a schedule, but you **must change it immediately** if you think it may be known to someone else.
- Never share your password or MFA codes (see the Code of Conduct).

3. Laptops and phones

- Only company-managed laptops may be used for work. Personal laptops can't connect to company systems.
- Your screen must lock after **5 minutes** without activity. Lock it yourself (Windows + L or Ctrl + Cmd + Q) whenever you step away.
- **USB storage devices are blocked.** Share files through Google Drive instead.
- Software is installed only from the Self Service portal. Requests for other software go through the IT Helpdesk.
- Personal phones may have Slack and email only if the company device-management profile is installed.

4. Phishing and suspicious messages

- If you receive a suspicious email or message, don't click anything. Use the "Report phishing" button in Gmail.
- **If you clicked a phishing link or entered your password on a suspicious page, report it to the security team within 30 minutes** on #security-alerts or by calling the IT Helpdesk. Then change your password.
- Reporting quickly is never punished, even if you clicked. Hiding it is a serious violation.

5. Lost or stolen devices

- Report a lost or stolen laptop or phone **within 2 hours** to the IT Helpdesk (24x7 phone line on the back of your ID card).
- IT wipes the device remotely. Then file a police report within 24 hours and share a copy with IT.
- Not reporting a lost device in time leads to a strike.

6. Customer and production data

- Production data is **Restricted**. Access needs the VPN plus a short-lived access ticket approved by an Engineering Manager.
- Customer data must never be copied to personal devices, personal email, staging or test fixtures.
- Never paste customer data, source code or credentials into public AI tools. Use only the approved internal tools, including Trellis.

7. Access reviews

- All access is reviewed every quarter by the Admins and the HR Manager.
- When someone leaves, their accounts are disabled at 18:00 on their last working day.
- When someone changes team, access they no longer need is removed within **5 working days**.

8. Security training

- New joiners complete security training within their **first 7 days**.
- Everyone repeats it **once a year**, by 31 March. People who miss the deadline have their account access paused until it's done.
- We run surprise phishing simulations four times a year.

9. Reporting a security incident

Anything that could be a security incident (a leaked file, a strange login alert, a customer reporting data they shouldn't see) goes to #security-alerts immediately. The security on-call engineer acknowledges within **15 minutes**, as for any P1 incident.